Lab-7 Email Forensics

Lab Objective

The objective of this lab is to analyze email files to identify legitimate and malicious emails. Students will perform email header analysis to detect phishing and CEO Fraud (BEC) attacks using standard forensic tools.

Extract and interpret key email header fields (From, Return-Path, Received, X-Originating-IP).
Perform SPF, DKIM, and DMARC validation using MXToolbox.
Classify each evidence email as Legitimate, Phishing, or Business Email Compromise (BEC).
Document findings in a structured investigative format.

Required Software

Tool	Purpose	Access
Mozilla Thunderbird	Open and inspect .eml evidence files	www.thunderbird.net (Free)
MXToolbox Email Analyzer	Parse headers — SPF, DKIM, DMARC, IP	mxtoolbox.com/EmailHeaders.aspx
Whois / IP Lookup	Trace and geolocate the originating IP	whois.domaintools.com

Installation

Download Thunderbird from www.thunderbird.net and run the installer.

On first launch click 'Skip this and use existing email' to bypass account setup.

Open a browser and confirm access to https://mxtoolbox.com/EmailHeaders.aspx.

Evidence Files

Three email evidence files are provided. Do not modify the originals. Open each file read-only.

ID	Email Type	Threat Category
EV01	Legitimate Business Email	Baseline / Control Sample
EV02	Phishing Email	Credential Harvesting Attack
EV03	CEO Fraud Email	Business Email Compromise (BEC)

Steps to Perform the Lab

Step 1 — Open Evidence Files in Thunderbird

Launch Mozilla Thunderbird.

Go to File > Open > Saved Message.

Select EV01.eml from the evidence folder and click Open.

Note the displayed From, To, Subject, and Date fields.

Repeat for EV02.eml and EV03.eml.

Step 2 — Extract Raw Email Headers

With an evidence file open, press Ctrl + U to open the raw message source.

Select all text from the first header field down to the blank line before the email body.

Copy the header text and paste it into Notepad. Save as EV01_header.txt (repeat for each file).

Step 3 — Analyze Headers Using MXToolbox

Go to https://mxtoolbox.com/EmailHeaders.aspx.

Paste the copied header into the input field and click Analyze Header.

Record the following from the results for each evidence file:

Originating IP Address and its geographic location.

SPF Result — Pass / Fail (fail = unauthorized sender).

DKIM Result — Pass / Fail (fail = message may be altered).

DMARC Result — Pass / Fail and the domain policy.

Number of relay hops in the Received: chain.

Take a screenshot of MXToolbox results and label it (e.g., EV01_MXToolbox.png).

Repeat steps 1–4 for EV02 and EV03.

Step 4 — Identify Phishing & BEC Indicators

Compare the From: display name against the actual email address — check for spoofing.

Look for lookalike domains (e.g., micros0ft.com vs microsoft.com).

Check for urgency language: 'Act immediately', 'Urgent transfer required', etc.

Identify any requests for credentials, wire transfers, or gift card purchases.

Note any geographic anomalies between the claimed sender and the originating IP location.

Email Header Fields Reference

Header Field	Description	Forensic Significance
From:	Claimed sender address	May be spoofed — verify against Return-Path

Return-Path:	Actual bounce/routing address	Key indicator for detecting spoofing
Received:	Relay server hops	Trace full delivery path; check each IP
X-Originating-IP:	IP of sending client machine	Geolocate the actual sender
DKIM-Signature:	Cryptographic domain signature	Verify message authenticity
Authentication-Results:	SPF / DKIM / DMARC results	Critical fraud detection indicator

6. Investigation Questions

Answer each question based on your forensic analysis. Support all answers with header data and MXToolbox results.

#	Question	Answer / Observation
1	Who is the sender of EV01? What domain does the email originate from?	
2	Is EV01 a legitimate email? Justify using SPF / DKIM / DMARC results.	
3	What action is EV02 requesting the recipient to perform?	
4	List at least two phishing indicators found in EV02.	
5	What specific request does the CEO Fraud email (EV03) make?	
6	Why is EV03 considered a high-risk BEC attack?	
7	Which evidence file is most dangerous and why?	